

Task 2: Phishing Awareness Training

Project Documentation, Real-World Case Studies & Interactive Quiz Walkthrough

Name	Muhammad Rizwan
Student ID	CA/DF1/172886
Project	CodeAlpha_PhishingAwareness
Deliverable 1	CodeAlpha_PhishingAwareness.pptx (13-slide training deck)
Deliverable 2	phishing_quiz.html (interactive 10-scenario quiz)

1. Objective

Task 2 of the CodeAlpha Cyber Security Internship required building a phishing awareness training resource covering how to recognize phishing emails and fake websites, common social engineering tactics, real-world examples, and best practices — delivered with an interactive quiz component for hands-on engagement.

This was completed as two linked deliverables: a 13-slide training presentation, and a standalone interactive HTML quiz module that lets a learner test their understanding against ten realistic phishing scenarios with instant feedback.

2. Deliverables Overview

CodeAlpha_PhishingAwareness.pptx

A 13-slide presentation covering: what phishing is and why it matters, the six major types of phishing (email, spear, whaling, smishing, vishing, clone), an annotated real-world example email, how to recognize fake websites, six social engineering tactics, three real-world breach case studies, best practices, and immediate incident-response steps.

phishing_quiz.html

A self-contained, browser-based interactive quiz (no installation or server required) presenting ten realistic phishing scenarios as multiple-choice questions. Each answer gives immediate feedback with a written explanation, a progress “reel” tracks position through the quiz, and a final results screen scores performance and offers a retake option.

3. How the Interactive Quiz Works

The quiz is built with plain HTML, CSS, and JavaScript so it runs entirely client-side in any modern browser. Each of the ten questions is stored as a JavaScript object containing the scenario type (mock email, URL comparison, SMS message, or plain scenario text), the question prompt, four answer options, the correct answer index, and an explanation string.

On selecting an answer, the interface immediately disables further input, highlights the correct option in green and an incorrect selection in red, and reveals the explanation panel. A “fishing reel” progress bar at the top of the page — a hook icon sliding along a line — tracks progress through the ten scenarios, and a row of dots records which questions were answered correctly or incorrectly at a glance. After the final question, a results screen totals the score and displays a tiered message (from “Sharp Eye” down to “Time to Recheck the Basics”) along with a button to retake the quiz.

4. Real-World Phishing Attacks — Detailed Case Studies

The five incidents below are all publicly documented, confirmed cases with verifiable financial and operational impact. Each is broken down by target, method, technical detail, and the specific lesson it teaches — going beyond the brief summaries in the slide deck to show exactly how each attack was carried out.

4.1 The Fake Quanta Computer Invoice Scam (Google & Facebook)

2013–2015 · Evaldas Rimasauskas · \$121M+ stolen via business email compromise

Attack method:

A Lithuanian man, Evaldas Rimasauskas, incorporated a company in Latvia under the exact same name as Quanta Computer, a real Taiwan-based hardware manufacturer that both Google and Facebook regularly paid for equipment. He and unnamed co-conspirators then emailed employees at both companies from fake accounts impersonating Quanta staff, sending invoices for goods and services that were never delivered.

Technical details:

The scheme was reinforced with forged contracts, letters, and invoices designed to look like they were signed by real Quanta executives, complete with fabricated corporate stamps. This documentation was submitted to banks to support the large wire transfers and avoid triggering fraud reviews. Because the emails impersonated a vendor the companies already had a genuine business relationship with, the requests didn't look out of place. The fraud continued for roughly two years (2013 to 2015) before it was detected.

Impact:

Facebook wired approximately \$99 million and Google approximately \$23 million to bank accounts Rimasauskas controlled in Latvia and Cyprus — over \$121 million combined. Both companies recovered most of the funds after alerting law enforcement, but Rimasauskas still pleaded guilty to wire fraud and was sentenced to five years in prison plus restitution.

Lesson: Even sophisticated tech companies can be fooled when a phishing email impersonates a real, trusted vendor rather than a random stranger. Payment requests — especially changes to invoices or banking details from an existing supplier — should always be verified through a separate, previously established contact method before money moves.

4.2 The Target Corporation HVAC Vendor Breach

November–December 2013 · Fazio Mechanical Services (third-party vendor) · 40 million payment cards, 70 million customer records

Attack method:

Attackers did not target Target directly. Instead, they sent a phishing email containing the Citadel banking trojan to employees at Fazio Mechanical Services, a small Pennsylvania HVAC contractor that had remote network access to Target for electronic billing and contract submission. An employee opened the email, and the malware harvested Fazio's network credentials.

Technical details:

With Fazio's stolen credentials, the attackers accessed a Target vendor portal that was not properly segmented from the rest of the corporate network. They moved laterally until they reached point-of-sale systems across

roughly 1,800 stores and installed custom malware that captured card data directly from the card-swipe hardware during checkout. Target's own FireEye security system did detect the malware and generated alerts — but the alerts were not acted on, and the breach continued undetected for about three weeks until an external payment processor flagged suspicious activity.

Impact:

Roughly 40 million credit and debit card numbers were stolen, along with the personal information (names, addresses, phone numbers) of an additional 70 million customers. Total costs to Target exceeded \$200 million, including an \$18.5 million multistate legal settlement, and both the CEO and CIO resigned in the aftermath.

Lesson: A phishing email doesn't have to hit the main target directly — attackers routinely go after smaller, less-secure third-party vendors as a stepping stone. Any organization granting network access to outside vendors needs to segment that access and monitor it as carefully as its own employees' access, and security alerts need a guaranteed human review process.

4.3 The Ubiquiti Networks CEO Fraud Wire Transfer

June 2015 · Ubiquiti Networks (Hong Kong subsidiary) · \$46.7 million transferred, ~\$32 million never recovered

Attack method:

Attackers impersonated senior executives and outside legal counsel in a series of emails sent to Ubiquiti's finance department, including messages that appeared to come from a real law firm (using a similar but different domain) discussing a confidential acquisition that required urgent, discreet wire transfers.

Technical details:

Over a 17-day period, Ubiquiti's finance team — believing the requests were legitimate — made 14 separate wire transfers from a Hong Kong subsidiary account to overseas accounts in countries including Russia, China, Hungary, and Poland. The company's own investigation found no evidence its systems were technically breached; the entire scheme worked purely through impersonation and trust, targeting a period when a senior finance controller had just resigned, reducing internal oversight.

Impact:

\$46.7 million was transferred before the FBI alerted Ubiquiti to the fraudulent Hong Kong account. The company recovered \$8.1 million relatively quickly and pursued further recovery, but a significant portion — roughly \$30 million — was never fully recovered. Ubiquiti's chief accounting officer resigned following the incident.

Lesson: Business email compromise (BEC) attacks often involve no malware or hacking at all — just carefully impersonated emails exploiting normal business processes. High-value wire transfers should always require a second, independent verification step — such as a phone call to a known, pre-verified number — that cannot be satisfied by replying to the same email thread.

4.4 The Twitter 2020 VPN Vishing / Bitcoin Scam

July 15, 2020 · Twitter, Inc. · 130 high-profile accounts compromised, ~\$118,000 in Bitcoin stolen

Attack method:

A group of hackers, including a then-17-year-old, called multiple Twitter employees by phone, claiming to be from Twitter's IT Help Desk responding to a reported VPN problem — a highly plausible pretext, since Twitter had recently shifted to remote work and VPN issues were common. The callers directed employees to a fake VPN login page that closely mimicked Twitter's real internal site, hosted on a similarly named look-alike domain, and harvested their login credentials there.

Technical details:

Using the stolen credentials, the attackers gained access to internal administrative “agent tools” used by Twitter's support staff to manage user accounts. This let them take over verified accounts belonging to Barack Obama, Joe Biden, Elon Musk, Bill Gates, Apple, and Uber, among others, and post a cryptocurrency “double your Bitcoin” scam simultaneously across all of them. The attack unfolded over roughly two hours before Twitter locked down the compromised accounts.

Impact:

More than 400 victims sent a combined total of roughly \$118,000 in Bitcoin to the attackers' wallet before the scam tweets were removed. Beyond the direct financial loss, the incident exposed a serious security gap in a platform used by hundreds of millions of people and prompted Twitter to significantly restrict internal tool access and improve employee security training.

Lesson: This was a voice-phishing (vishing), not email, attack — a reminder that phishing training needs to cover phone calls, not just inboxes. Attackers also did reconnaissance on employees beforehand (studying who had access to sensitive internal tools), showing that even a company built on cutting-edge technology can be compromised through simple, well-researched human impersonation.

4.5 The MGM Resorts Help-Desk Vishing / Ransomware Attack

September 2023 · MGM Resorts International · ~\$100 million operational loss, 10-day outage

Attack method:

The threat group Scattered Spider researched an MGM employee's profile on LinkedIn to gather enough personal detail to sound convincing, then placed a single approximately 10-minute phone call to MGM's IT help desk, impersonating that employee and claiming to be locked out of their account. The help desk reset the employee's multi-factor authentication (MFA) without verifying the caller through a stronger method — handing the attackers a way in that bypassed MFA entirely.

Technical details:

With the reset credentials, the attackers gained access to MGM's Okta identity provider, which controlled single sign-on across the company's systems, and configured a rogue identity provider using an “inbound federation” feature to maintain persistent access. From there they moved into MGM's Microsoft Azure cloud environment and ultimately deployed ransomware (attributed to the ALPHV/BlackCat group) against several hundred servers.

Impact:

The attack knocked out slot machines, digital room keys, hotel websites, and reservation systems across MGM's properties for roughly ten days, guests had to be checked in manually, and MGM reported approximately \$100 million in losses for the affected quarter. A related attack the same month against Caesars Entertainment, using similar tactics, resulted in Caesars paying a \$15 million ransom.

Lesson: A single 10-minute phone call bypassed MFA entirely by exploiting a human process, not a technical flaw — proving that even modern authentication systems are only as strong as the identity-verification process behind help-desk password and MFA resets. Organizations need help-desk verification procedures that can't be defeated by information available on LinkedIn or social media.

5. Practical Detection Techniques

Beyond recognizing obvious red flags, these are concrete, repeatable techniques anyone can use to verify a suspicious email, link, or login page before interacting with it.

5.1 Inspecting the Real Sender Address

- Click or tap the sender's display name to reveal the full underlying email address — never trust the display name alone.
- Read the domain from right to left: the part immediately before the first single slash or the end of the address is what matters, not any brand name that appears earlier in the string.
- Watch for character substitution (paypa1.com using the digit “1” instead of “l”), extra words (paypal-secure-login.com), or a completely unrelated domain hosting the display name “PayPal Security.”

Example — a fraudulent address might display as: PayPal Security <service@paypal-account-verify-secure.com>. The visible name says PayPal, but the actual domain (paypal-account-verify-secure.com) has no connection to paypal.com at all.

5.2 Checking a Link Before Clicking

- On desktop, hover the mouse over a link without clicking — most email clients and browsers show the real destination URL in a status bar or tooltip.
- On mobile, press and hold a link to preview the destination before opening it.
- For shortened URLs (bit.ly, tinyurl, etc.), use a link-expander tool or a browser extension to reveal the full destination before visiting it — shorteners are frequently used specifically to hide a suspicious domain.
- Read the expanded URL the same way as an email domain: identify the actual registrable domain, ignoring subdomains or path text designed to look reassuring.

5.3 Verifying a Domain's Trustworthiness

- Use a WHOIS lookup tool to check when a domain was registered — a domain created days or weeks ago is a strong warning sign for anything claiming to be an established company.
- Check whether the domain matches the company's officially published domain exactly (found via a separate search, not the link in the suspicious message itself).
- For a login page specifically, click the padlock icon in the browser and check the certificate details — confirm the certificate was issued for the exact expected domain, since attackers can obtain valid certificates for their own look-alike domains too.

5.4 Verifying Unexpected Financial or Access Requests

- Never verify a suspicious request by replying to the same email thread, chat, or phone number it arrived through — a compromised or spoofed channel will just confirm the request with the attacker.

- Look up the requester's phone number independently (company directory, previous correspondence, official website) rather than using any number provided in the suspicious message.
- For financial requests specifically, apply a two-person rule: any change to payment details or a new urgent wire transfer should require a second person's independent sign-off before it's executed.
- For IT help-desk or account-reset requests, confirm identity using a method that can't be answered from public information like LinkedIn — a callback to a pre-registered phone number, not information the caller can simply state.

5.5 Responding to Suspicious Multi-Factor Authentication (MFA) Prompts

- Never approve an MFA push notification that wasn't triggered by your own login attempt, even if it arrives only once.
- If unexpected prompts continue arriving (“MFA fatigue” or “push bombing”), change the account password immediately and report it to IT/security rather than approving a prompt just to make it stop.
- Where possible, prefer number-matching or phishing-resistant MFA (security keys, passkeys) over simple approve/deny push notifications, since these are harder to approve accidentally or under pressure.

5.6 Reporting and Escalation Checklist

- Use the organization's built-in “Report Phishing” button where available — this automatically forwards the message with full technical headers to the security team.
- If no reporting button exists, forward the suspicious message as an attachment (not inline) to the security or IT team, which preserves the original headers needed for investigation.
- Do not delete the message until it has been reported — security teams often need the original for analysis.
- If credentials were already entered into a suspicious site, change the password and check for unusual activity immediately, in addition to reporting.

6. Quiz Walkthrough — All 10 Scenarios

The screenshots below were captured while completing the quiz in Microsoft Edge, showing every scenario, the option selected, and the resulting feedback panel.

6.1 Scenario 1 — Mismatched Sender Domain

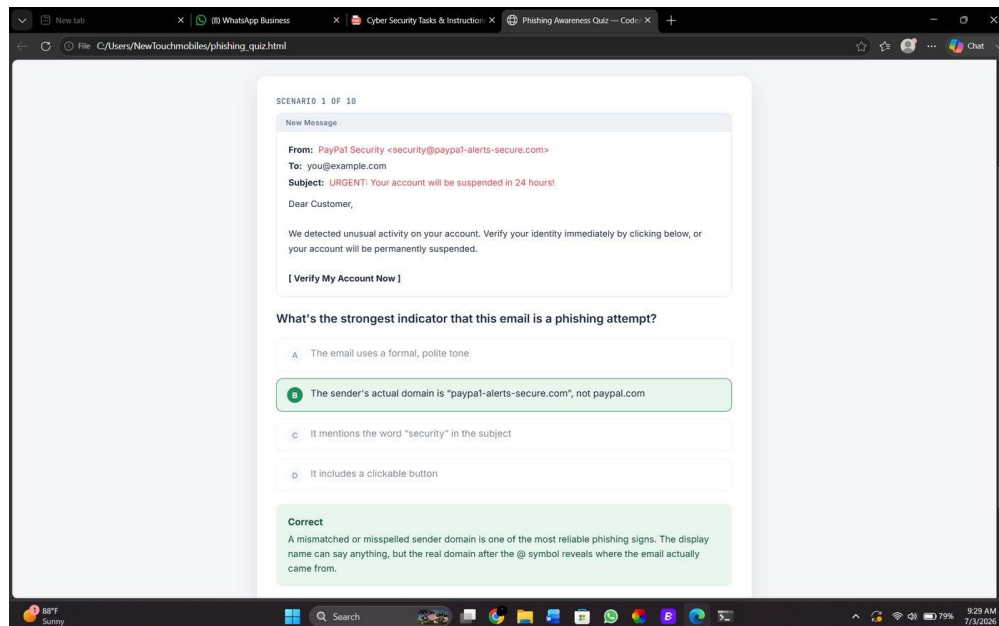


Figure 1: In-browser view of Scenario 1 of the interactive phishing quiz.

Scenario: A mock “PayPal Security” email urging urgent account verification.

Question: *What's the strongest indicator that this email is a phishing attempt?*

Correct answer: The sender's actual domain is “paypal1-alerts-secure.com”, not paypal.com.

A mismatched or misspelled sender domain is one of the most reliable phishing signs. The display name can say anything, but the real domain after the @ symbol reveals where the email actually came from.

6.2 Scenario 2 — Lookalike URL vs. the Real Domain

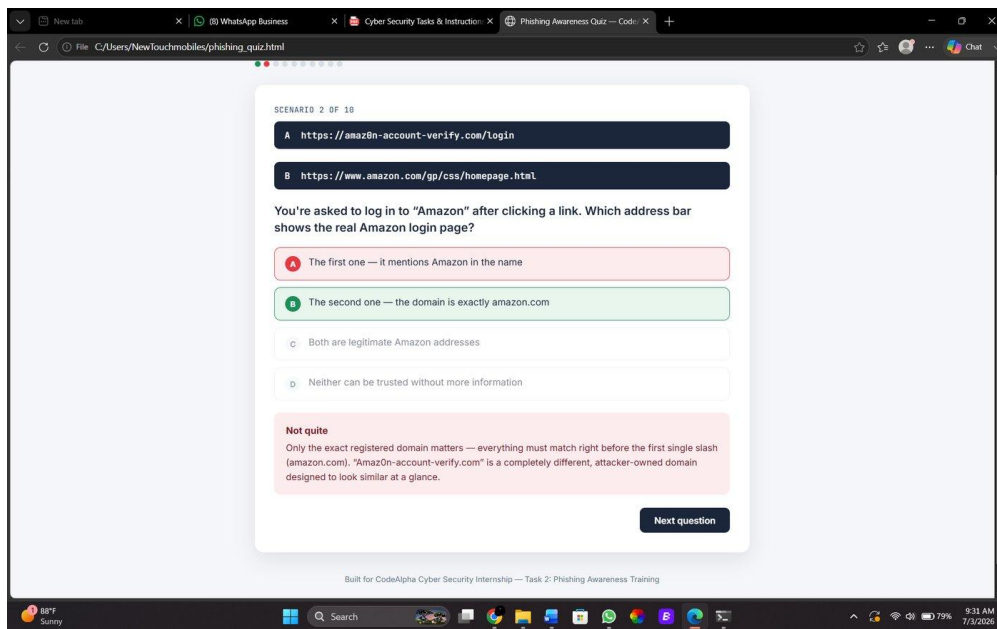


Figure 2: In-browser view of Scenario 2 of the interactive phishing quiz.

Scenario: Two address bars are shown side by side, one for a lookalike domain and one for the genuine Amazon domain.

Question: Which address bar shows the real Amazon login page?

Correct answer: The second one — the domain is exactly amazon.com.

Only the exact registered domain matters — everything must match right before the first single slash. “AmazOn-account-verify.com” is a completely different, attacker-owned domain designed to look similar at a glance. (This screenshot shows the answer being tested with the wrong option selected, triggering the “Not quite” feedback state.)

6.3 Scenario 3 — Smishing via Fake Delivery Alert

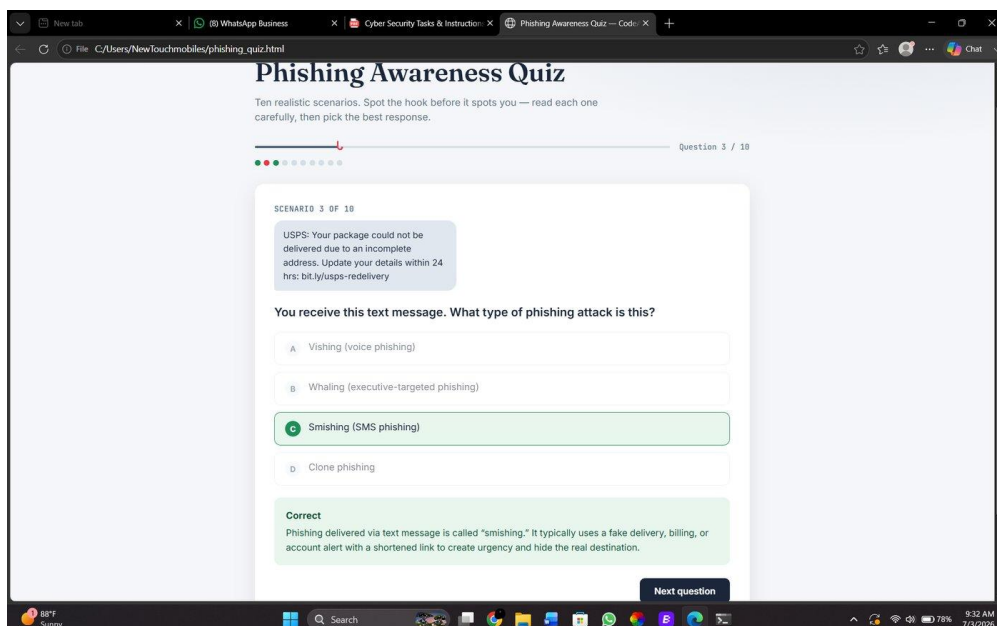


Figure 3: In-browser view of Scenario 3 of the interactive phishing quiz.

Scenario: A text message impersonating USPS, warning of a failed delivery and pushing a shortened link.

Question: What type of phishing attack is this?

Correct answer: Smishing (SMS phishing).

Phishing delivered via text message is called “smishing.” It typically uses a fake delivery, billing, or account alert with a shortened link to create urgency and hide the real destination.

6.4 Scenario 4 — Vishing Phone Call

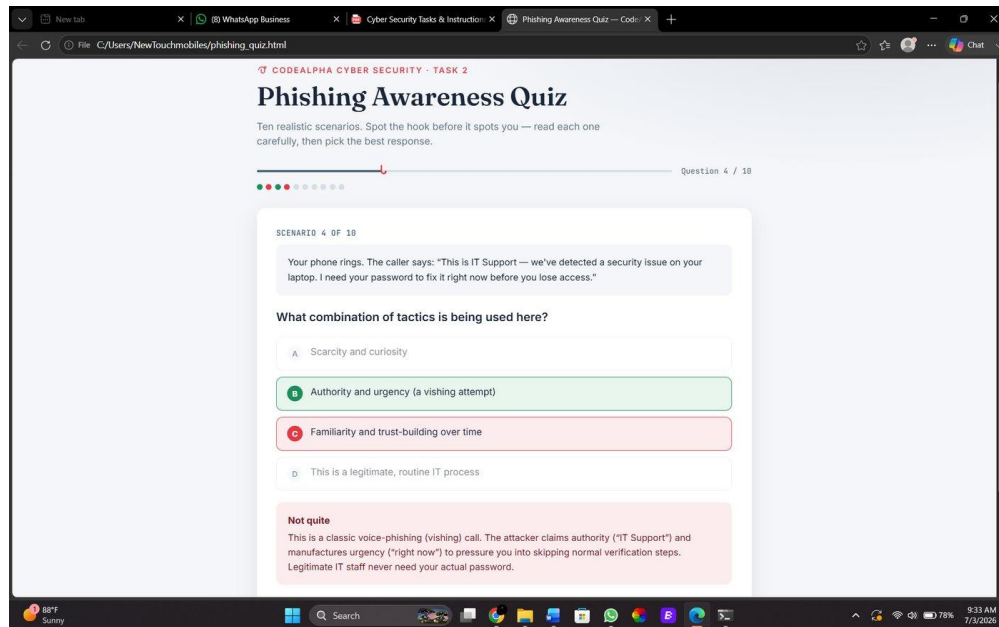


Figure 4: In-browser view of Scenario 4 of the interactive phishing quiz.

Scenario: A caller claiming to be “IT Support” demands a password to “fix” an urgent issue.

Question: What combination of tactics is being used here?

Correct answer: Authority and urgency (a vishing attempt).

This is a classic voice-phishing (vishing) call. The attacker claims authority (“IT Support”) and manufactures urgency (“right now”) to pressure the target into skipping normal verification steps. Legitimate IT staff never need an actual password.

6.5 Scenario 5 — Subdomain Spoofing Trick

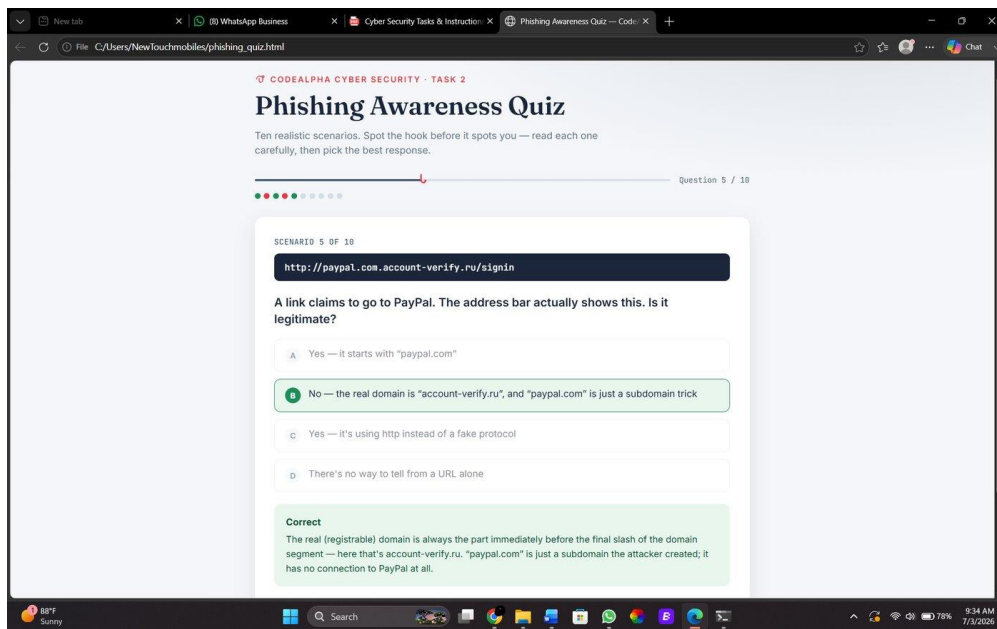


Figure 5: In-browser view of Scenario 5 of the interactive phishing quiz.

Scenario: A URL formatted as “paypal.com.account-verify.ru”, designed to look like PayPal at a glance.

Question: *Is this address legitimate?*

Correct answer: No — the real domain is “account-verify.ru”, and “paypal.com” is just a subdomain trick.

The real (registrable) domain is always the part immediately before the final slash of the domain segment — here that's account-verify.ru. “paypal.com” is just a subdomain the attacker created; it has no connection to PayPal at all.

6.6 Scenario 6 — Whaling / CEO Fraud

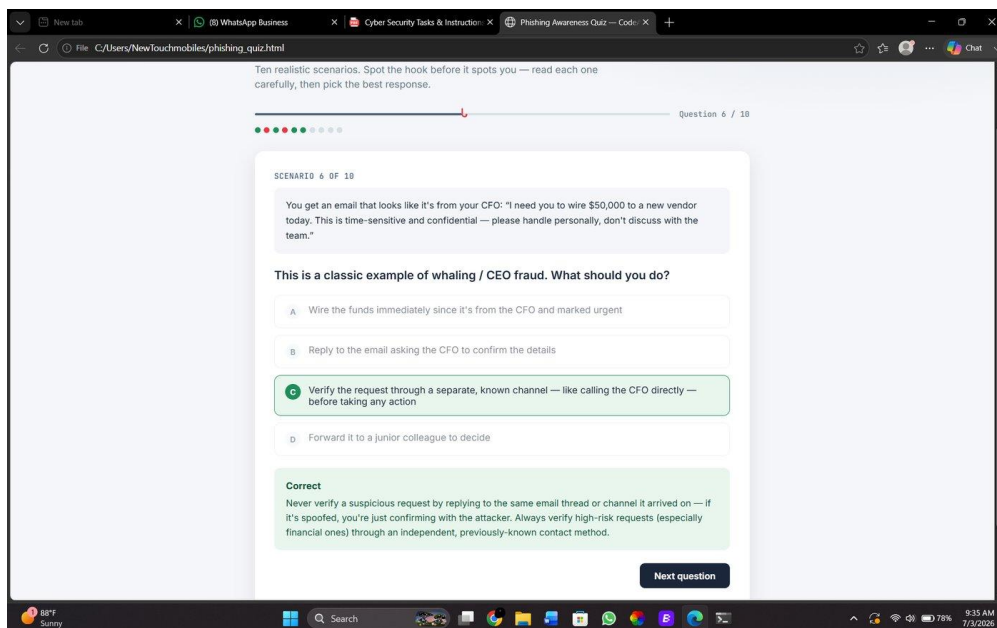


Figure 6: In-browser view of Scenario 6 of the interactive phishing quiz.

Scenario: An email impersonating a CFO, urgently requesting a \$50,000 wire transfer to a new vendor and asking that it be kept confidential.

Question: *What should you do?*

Correct answer: Verify the request through a separate, known channel — like calling the CFO directly — before taking any action.

Never verify a suspicious request by replying to the same email thread or channel it arrived on — if it's spoofed, that only confirms the request with the attacker. High-risk requests, especially financial ones, should always be verified through an independent, previously-known contact method.

6.7 Scenario 7 — Malicious Double-Extension Attachment

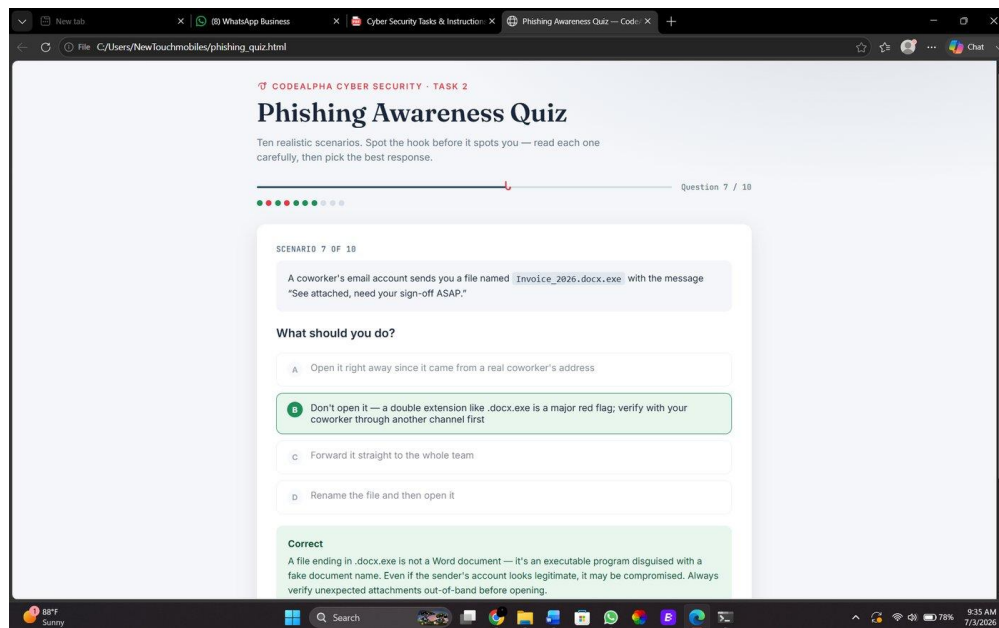


Figure 7: In-browser view of Scenario 7 of the interactive phishing quiz.

Scenario: A coworker's account sends a file named “Invoice_2026.docx.exe” with a request for urgent sign-off.

Question: *What should you do?*

Correct answer: Don't open it — a double extension like .docx.exe is a major red flag; verify with the coworker through another channel first.

A file ending in .docx.exe is not a Word document — it's an executable program disguised with a fake document name. Even if the sender's account looks legitimate, it may be compromised. Always verify unexpected attachments out-of-band before opening them.

6.8 Scenario 8 — MFA Fatigue Attack

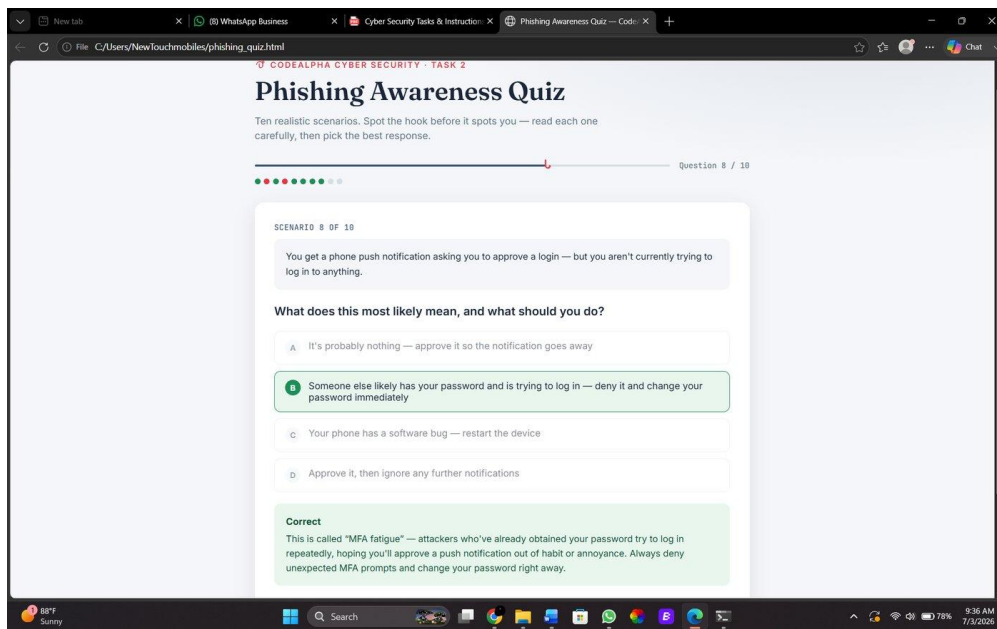


Figure 8: In-browser view of Scenario 8 of the interactive phishing quiz.

Scenario: An unexpected multi-factor authentication push notification arrives with no login attempt initiated by the user.

Question: *What does this most likely mean, and what should you do?*

Correct answer: Someone else likely has your password and is trying to log in — deny it and change your password immediately.

This is called “MFA fatigue” — attackers who have already obtained a password try to log in repeatedly, hoping the target will approve a push notification out of habit or annoyance. Unexpected MFA prompts should always be denied, followed by an immediate password change.

6.9 Scenario 9 — Tech-Support Scam (Fear + False Authority)

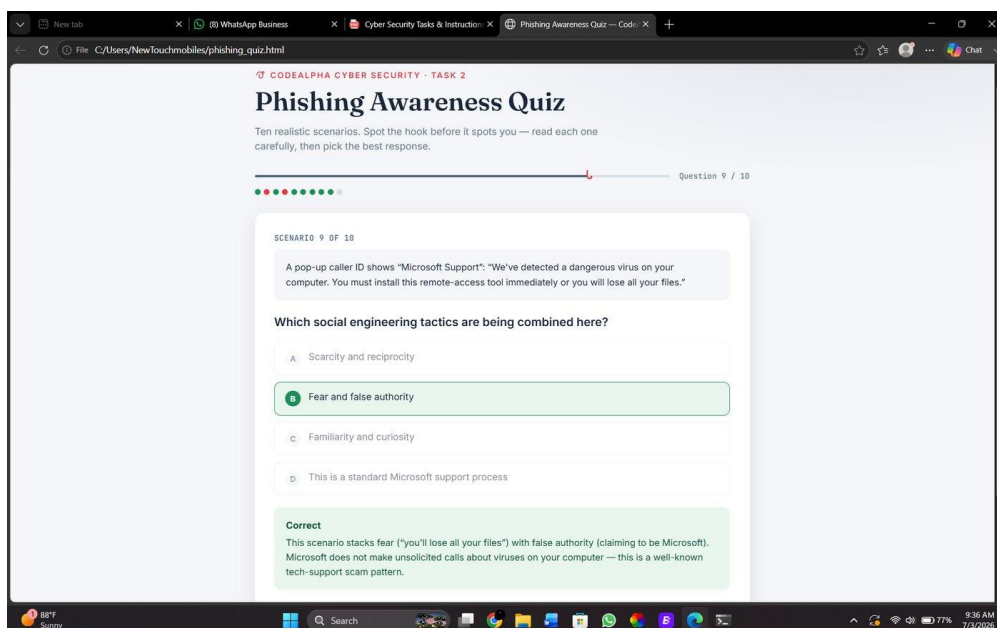


Figure 9: In-browser view of Scenario 9 of the interactive phishing quiz.

Scenario: A pop-up caller ID claiming to be “Microsoft Support” warns of a dangerous virus and pressures the installation of a remote-access tool.

Question: Which social engineering tactics are being combined here?

Correct answer: Fear and false authority.

This scenario stacks fear (“you’ll lose all your files”) with false authority (claiming to be Microsoft). Microsoft does not make unsolicited calls about viruses on a computer — this is a well-known tech-support scam pattern.

6.10 Scenario 10 — Correct Incident Reporting

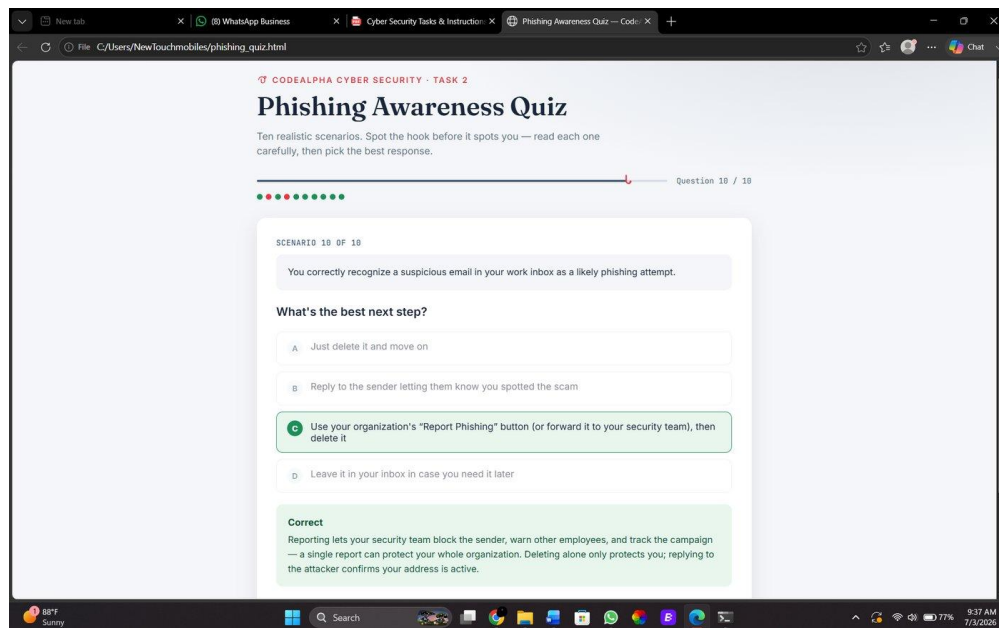


Figure 10: In-browser view of Scenario 10 of the interactive phishing quiz.

Scenario: A suspicious email has been correctly identified in a work inbox as a likely phishing attempt.

Question: What's the best next step?

Correct answer: Use your organization's “Report Phishing” button (or forward it to your security team), then delete it.

Reporting lets the security team block the sender, warn other employees, and track the campaign — a single report can protect an entire organization. Deleting alone only protects the individual; replying to the attacker confirms the address is active.

7. Key Learnings

- Recognizing phishing reliably comes down to a small set of repeatable checks: verify the sender's actual domain, hover over links before clicking, and be suspicious of any message that manufactures urgency or fear.
- Attackers combine multiple social engineering tactics in a single message — the quiz scenarios frequently paired authority with urgency, or fear with false authority, rather than relying on just one trick.
- Technical protections like MFA are powerful but not foolproof; “MFA fatigue” attacks (and the MGM Resorts case) show why users and help desks still need to recognize and deny unexpected or unverified reset requests rather than approving them automatically.
- URL inspection requires checking the exact registrable domain, not just scanning for a familiar brand name anywhere in the address — lookalike characters and subdomain tricks are both common, and were central to the Twitter 2020 and PayPal-style scenarios alike.
- Some of the largest phishing losses in history — Google/Facebook, Ubiquiti — involved no malware or hacking at all, only convincing impersonation of a trusted vendor or executive. Technical defenses alone cannot stop a well-crafted, targeted social engineering attempt.
- Third-party vendors and IT help desks are common weak points, as seen in the Target and MGM cases. An organization's phishing defenses are only as strong as the least-trained party with access to its systems.
- Reporting suspicious messages (rather than only deleting them) has an organization-wide benefit, since it allows a security team to block senders and warn other potential targets.

8. Conclusion

Together, the presentation, five in-depth real-world case studies, the practical detection techniques, and the interactive quiz fulfill all the requirements of Task 2: they explain how to recognize phishing emails and fake websites, cover the social engineering tactics attackers rely on, provide detailed real-world examples with confirmed technical and financial impact, give concrete step-by-step verification techniques, and offer a hands-on way to test and reinforce understanding through interactive, scenario-based quizzing.